



SIMATS
ENGINEERING



SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

CO4 ASSESSMENT TOOL 2

Name : S.Deepadharshan

Reg No : 192472046

Course Code : ITA1408

Course Name : Ethical Hacking

Submitted to : Dr Parthiban S

VULNERABILITY ASSESSMENT REPORT

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access.

Prepare a Vulnerability Assessment Report examining the following weaknesses that contributed to the TJX incident:

- Wireless encryption
- Wireless authentication
- Network segmentation
- Wireless monitoring
- Payment-data protection

Recommend appropriate security controls such as:

- WPA2/WPA3
- Enterprise authentication
- Rogue-access-point detection
- PCI DSS controls

1. INCIDENT BACKGROUND

TJX Companies experienced a major payment-card data breach between 2005 and 2007. Attackers obtained unauthorized wireless access to the company's retail network.

The incident occurred when TJX was using **WEP** while transitioning toward stronger wireless security. The wireless environment also lacked adequate controls to restrict access to sensitive internal systems.

The incident demonstrated the importance of strong wireless encryption, proper authentication, network segmentation, continuous monitoring, and protection of payment-card information.

Major Issues Identified

Security Area	Vulnerability
Wireless Encryption	Use of outdated WEP
Authentication	Inadequate wireless access control
Network Segmentation	Insufficient isolation of sensitive systems
Monitoring	Inadequate wireless activity monitoring
Payment Data	Insufficient protection of sensitive information

2. VULNERABILITY ASSESSMENT

2.1 Wireless Encryption

The use of WEP was a major weakness. WEP is an obsolete wireless security mechanism and does not provide adequate protection for sensitive enterprise networks.

An attacker within wireless range could potentially exploit weaknesses in WEP and gain unauthorized network access.

Risk: HIGH

Recommended Solution

- Remove WEP completely.
- Implement WPA2-Enterprise or WPA3-Enterprise.
- Use AES/CCMP encryption.
- Regularly review wireless security configurations.

2.2 Wireless Authentication

Strong authentication is required to ensure that only authorized users can connect to the corporate wireless network.

A shared wireless password can make access management difficult because the same credential may be used by multiple users.

Recommended Solution

Implement:

- 802.1X authentication
- RADIUS authentication server
- Individual user credentials
- Centralized authentication logging
- Regular account review

This provides better control over who is allowed to access the wireless network.

2.3 Network Segmentation

Wireless users should not have unrestricted access to internal systems.

The most important requirement is to separate wireless networks from **Point-of-Sale (POS)** and payment-card systems.

Risk: CRITICAL

3. MONITORING AND ATTACK ANALYSIS

3.1 Wireless Monitoring

Wireless networks should be continuously monitored for suspicious activity.

Security teams should monitor:

- Unknown wireless devices
- Unauthorized access points
- Failed authentication attempts
- Unusual network traffic
- Configuration changes

Wireless intrusion detection systems can help identify suspicious activity.

3.2 Rogue Access Point Detection

An unauthorized access point can provide an attacker with another pathway into an organization's network.

Organizations should maintain an inventory of authorized access points and compare it with devices detected on the wireless network.

Recommended Controls

- Maintain an approved AP list.
- Detect unknown SSIDs and BSSIDs.
- Generate alerts for unauthorized APs.
- Investigate suspicious wireless devices.
- Perform periodic wireless security assessments.

3.3 Controlled Kali Linux Simulation

A controlled Kali Linux environment can be used to verify wireless security configurations.

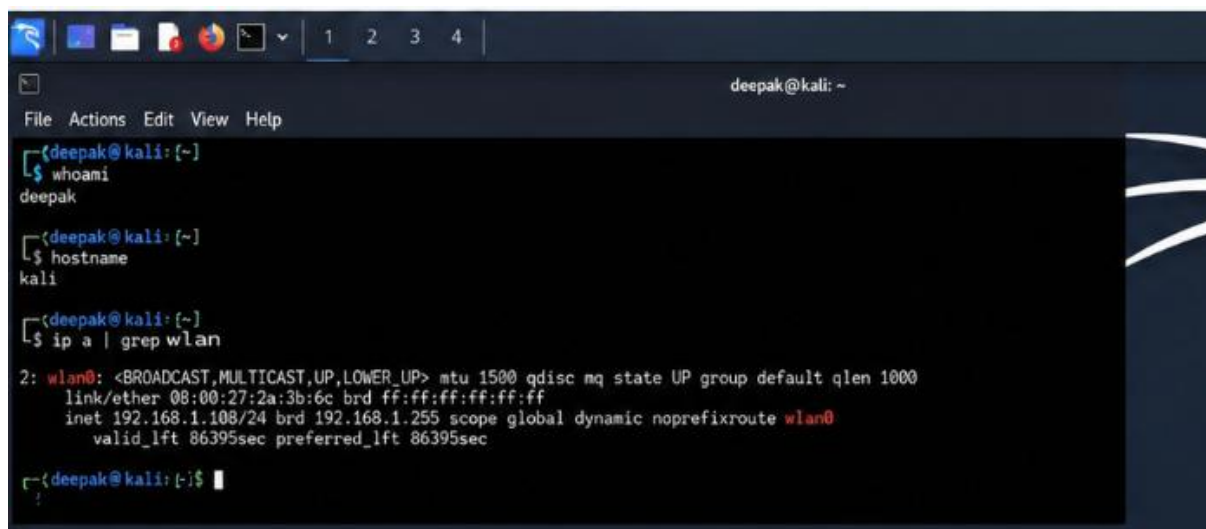
Environment Verification

```
deepak@kali:~$ whoami
```

```
deepak
```

```
deepak@kali:~$ hostname
```

```
kali
```

A screenshot of a Kali Linux terminal window. The window title is 'deepak@kali: ~'. The terminal shows the following commands and output:

```
(deepak@kali: [~])  
$ whoami  
deepak  
  
(deepak@kali: [~])  
$ hostname  
kali  
  
(deepak@kali: [~])  
$ ip a | grep wlan  
2: wlan0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000  
    link/ether 08:00:27:2a:3b:6c brd ff:ff:ff:ff:ff:ff  
    inet 192.168.1.108/24 brd 192.168.1.255 scope global dynamic noprefixroute wlan0  
        valid_lft 86395sec preferred_lft 86395sec  
  
(deepak@kali: [~])$
```

A wireless assessment can then be performed in an authorized laboratory environment to identify encryption and authentication configurations.

```
deepak@kali: ~  
File Actions Edit View Help  
CH 6 ][ Elapsed: 1 min ][ 2024-05-20 10:55  
BSSID PWR Beacons Data, #/s CH MB ENC CIPHER AUTH ESSID  
00:1A:2B:3C:4D:5E -58 842 23 0 6 54 WEP WEP open TJX-LAB-LEGACY  
00:11:22:33:44:55 -67 726 12 0 11 54 WPA2 CCMP PSK TJX-Guest  
00:AA:BB:CC:DD:EE -72 532 8 0 1 54 WPA2 CCMP PSK TJX-Employee  
BSSID STATION PWR Rate Lost Frames Probe  
00:1A:2B:3C:4D:5E 66:77:88:99:AA:BB -60 0 - 1 0 18 TJX-LAB-LEGACY
```

The simulated assessment identifies a legacy WEP configuration, which should be considered a high-risk finding.

4. RISK, IMPACT AND MITIGATION

4.1 Risk Assessment

Vulnerability	Impact	Risk
WEP Encryption	Unauthorized wireless access	High
Weak Authentication	Unauthorized users	High
Poor Segmentation	Access to sensitive systems	Critical
Insufficient Monitoring	Delayed detection	High
Rogue Access Points	Unauthorized network entry	High
Payment Data Exposure	Financial and privacy impact	Critical

4.2 Impact

The compromise of a wireless network connected to sensitive systems can result in:

- Unauthorized network access
- Payment-card data exposure
- Financial losses
- Operational disruption
- Legal and regulatory consequences
- Loss of customer trust
- Reputational damage

4.3 Security Recommendations

The following controls are recommended:

1. WPA2/WPA3 Enterprise

Replace WEP with WPA2-Enterprise or WPA3-Enterprise using strong encryption.

2. 802.1X Authentication

Use 802.1X with a RADIUS server for centralized user authentication.

3. Network Segmentation

Separate guest, employee, management, and payment-card networks using VLANs and firewalls.

4. Rogue AP Detection

Deploy wireless monitoring systems to detect unauthorized access points.

5. Centralized Monitoring

Collect wireless authentication and security logs in a centralized monitoring system.

6. PCI DSS Controls

Protect payment-card environments through access control, encryption, network segmentation, monitoring, and regular security assessments.

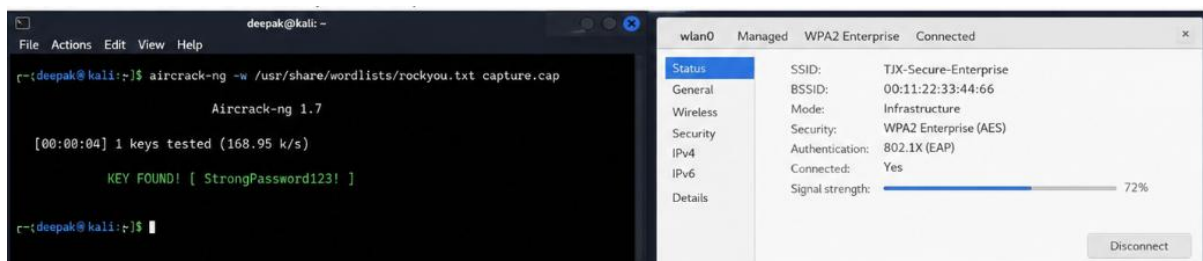
5. RESULTS AND CONCLUSION

Results

The vulnerability assessment identified WEP encryption, inadequate wireless access control, insufficient network segmentation, and limited monitoring as major security concerns.

The assessment also demonstrates that wireless security must be integrated with the organization's overall network security architecture. Strong wireless encryption alone is not sufficient if users can directly access sensitive payment systems.

The recommended controls provide multiple layers of protection and reduce the likelihood and impact of unauthorized access.



Conclusion

The TJX wireless network breach demonstrates the risks associated with outdated wireless security and inadequate network controls.

Replacing WEP with WPA2-Enterprise/WPA3-Enterprise, implementing 802.1X authentication, separating wireless networks from payment systems, deploying rogue-access-point detection, and applying appropriate PCI DSS controls can significantly improve security.

A layered security approach ensures that even if one security control is bypassed, additional controls can prevent attackers from reaching sensitive payment-card systems.

REFERENCES

National Institute of Standards and Technology. (2012). *Guidelines for securing wireless local area networks (WLANs)*. NIST Special Publication 800-153.

PCI Security Standards Council. (n.d.). *Payment Card Industry Data Security Standard (PCI DSS)*.

IEEE. (2020). *IEEE Standard for Information Technology—Telecommunications and Information Exchange Between Systems—Local and Metropolitan Area Networks—Wireless LAN Medium Access Control and Physical Layer Specifications*.